Security Assessment Report

TARGET URL	https://delta.co.zw/
SCAN ID	–
GENERATED	2026-05-26 11:45 UTC

0/100 Security Score — Critical Risk

Executive Summary

38 security issues were detected across this scan. These findings should be reviewed and remediated promptly.

HTTP Header Issues	4
WordPress Issues	6
OWASP ZAP Alerts	20
Technology Exposure	1
Sensitive File Exposure	2

Detailed Findings

✓ SQL Injection Analysis

No issues detected

✓ No SQL injection vulnerabilities were detected.

✓ SSL/TLS Certificate

Valid certificate

Issuer	Sectigo Limited
Subject	delta.co.zw
Expires	Jun 30 23:59:59 2026 GMT
Protocol	TLSv1.3

✗ HTTP Header Security

4 issues found

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

Information disclosure via server — Low

server: nginx

CSP missing object-src — Low

Add object-src 'none' to block Flash and other plugin execution.

CSP missing base-uri — Low

Add base-uri 'self' to prevent base tag hijacking.

HSTS missing preload directive — Low

Add 'preload' to HSTS and submit to the HSTS preload list for stronger protection.

- Suppress or genericise the Server header to avoid version disclosure.
- Add the 'preload' directive to your HSTS header and submit to hstspreload.org.

✗ WordPress Security

6 issues found

WordPress version exposed — Low

Version 7.0 exposed via meta_generator.

Outdated WordPress plugin — High

age-gate appears to be 3.4.0; latest available is 3.7.2.

Outdated WordPress plugin — High

contact-form-7 appears to be 5.9.4; latest available is 6.1.6.

Outdated WordPress plugin — High

popup-maker appears to be 1.19.0; latest available is 1.22.0.

Outdated WordPress plugin — High

gtm-kit appears to be 1.23; latest available is 2.13.1.

Outdated WordPress plugin — High

megamenu appears to be 3.3.1; latest available is 3.10.

- Reduce public WordPress version exposure in generator tags and public files.
- Update installed WordPress plugins to their latest supported versions.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

✗ OWASP ZAP Analysis

20 alerts

Tech Detected - HSTS	Informational
Strict-Transport-Security	
Re-examine Cache-control Directives	Informational
The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For	
CSP: Failure to Define Directive with No Fallback	Medium
frame-ancestors 'none'	
CSP: Wildcard Directive	Medium
frame-ancestors 'none'	
CSP: script-src unsafe-inline	Medium
frame-ancestors 'none'	
CSP: style-src unsafe-inline	Medium
frame-ancestors 'none'	
Cross-Domain JavaScript Source File Inclusion	Low
<script id="google_gtagjs-js" src="https://www.googletagmanager.com/gtag/js?id=GT-NGP9TMBS" async></script>	
Cross-Domain JavaScript Source File Inclusion	Low
<script id="google-recaptcha-js" src="https://www.google.com/recaptcha/api.js?render=6Lc4AgkqAAAAACnTgTHkAs3FJer6ANwDqEz	
Absence of Anti-CSRF Tokens	Medium
<form method="post" class="age-gate__form">	
Tech Detected - Google Analytics	Informational
googletagmanager.com/gtag/js	
Tech Detected - Google Font API	Informational
fonts.googleapis.com	
Information Disclosure - Suspicious Comments	Informational
of time we want the user to touch before we	
Information Disclosure - Suspicious Comments	Informational

stops short touches from firing the event

Modern Web Application — Informational

<a class="mega-menu-link" href="#" aria-haspopup="true" aria-expanded="false" tabindex="0">ABOUT US<span class="mega-ind

Sub Resource Integrity Attribute Missing — Medium

<link rel='stylesheet' id='google-font-barlow-css' href='https://fonts.googleapis.com/css?family=Barlow:300,400,700&#038

Sub Resource Integrity Attribute Missing — Medium

<link rel='stylesheet' id='google-font-roboto-css' href='https://fonts.googleapis.com/css?family=Roboto:100,300,400,500,

Sub Resource Integrity Attribute Missing — Medium

<script id="google_gtagjs-js" src="https://www.googletagmanager.com/gtag/js?id=GT-NGP9TMBS" async></script>

Sub Resource Integrity Attribute Missing — Medium

<script id="google-recaptcha-js" src="https://www.google.com/recaptcha/api.js?render=6Lc4AgkqAAAAACnTgTHkAs3FJer6ANwDqEz

Timestamp Disclosure - Unix — Low

1999999999

Tech Detected - Google Tag Manager — Informational

.googletagmanager.com/

✓ Malicious Content Analysis

No threats detected

✓ **No malicious indicators detected.**

Threat Score: 0/10

✓ Cross-Site Scripting (XSS)

No reflected XSS detected

✓ **No reflected XSS vectors detected in tested parameters.**

✗ Technology Fingerprinting

1 actionable issue found

Cms	WordPress
Javascript Libraries	core-js
Web Servers	Nginx

Analytics	Google Analytics
Tag Managers	Google Tag Manager
Miscellaneous	JSON-LD, Open Graph, RSS
Databases	MySQL
Ecommerce	WooCommerce
Programming Languages	PHP
Wordpress Plugins	*, age-gate, codevz-plus, contact-form-7, gtm-kit, js_composer, megamenu, organization-chart, popup-maker, revslider, revslider-transitionpack-addon, woocommerce, wp-content-copy-protector

Server version exposed in headers — Low

nginx

Detected: Wordpress — Info

Identified in the tech stack.

Detected: Woocommerce — Info

Identified in the tech stack.

Detected: Php — Info

Identified in the tech stack.

Detected: Nginx — Info

Identified in the tech stack.

- Hide server version (ServerTokens Prod / server_tokens off).
- Ensure WordPress core, themes, and plugins are up to date.
- WooCommerce handles payments — ensure PCI compliance and keep plugins updated.
- Ensure PHP version is current and not end-of-life.
- Ensure Nginx is patched and server banner is hidden.

✗ **Sensitive File Exposure**
2 paths exposed

WordPress REST API user enumeration

SEVERITY	Medium
URL	https://delta.co.zw/wp-json/wp/v2/users
SIZE	1,410 bytes
PREVIEW	[{"id":1,"name":"digital","url":"https:\/\/delta.co.zw","description":"","link":"https:\/\/delta.co.zw\/author\/digital\/","slug":"digital","avatar_urls":{"24":"https:\/\/secure.gravatar.com\/avatar\/ecb157dfe2a7d5c9e71cda7b0a1ab9a530625d39b0954aa885aaca30b41dcaf0?s=24&d=mm&r=g","48":"https:\/\/secure.gravatar.com\/avatar\/ecb157dfe2a7d5c9e71cda7b0a1ab9a530625d39b0954aa885aaca30b41dcaf0?s=48&d=mm&

WordPress REST API root exposed

SEVERITY	Low
URL	https://delta.co.zw/wp-json/
SIZE	1,218,582 bytes
PREVIEW	{"name":"Delta Corporation Limited","description":"Modern Zimbabwean Company","url":"https:\/\/delta.co.zw","home":"https:\/\/delta.co.zw","gmt_offset":"0","timezone_string":"","page_for_posts":0,"page_on_front":12,"show_on_front":"page","namespaces":["oembed\/1.0","age-gate\/v3","contact-form-7\/v1","ninjatables\/v2","sliderrevolution","wc\/v3","yoast\/v1","jetpack\/v4","pum\/v1","gtmkit\/v1","iw

- Delete WordPress config backups; use `deny all` in Nginx or block via `.htaccess`.

✗ DNS Security (SPF / DMARC / DKIM)

5 issues

SPF soft fail (~all) — Low

~all marks unauthorized senders as suspicious but does not reject them. Use -all for enforcement.

DMARC subdomain policy not set — Low

Without sp=, subdomains inherit the root policy which may not be intended.

No DKIM record found (common selectors checked) — Medium

None of the common DKIM selectors (default, google, mail, k1, selector1, selector2, dkim, email, smtp) returned a DKIM1

DNSSEC not enabled — Low

No DS or DNSKEY records found for delta.co.zw. DNSSEC prevents DNS cache poisoning attacks.

No CAA record — Low

No CAA record for delta.co.zw. Any CA can issue certificates for this domain.

- Consider changing ~all to -all in your SPF record for strict enforcement.
- Add sp=reject to your DMARC record to apply the same policy to all subdomains.
- Configure DKIM signing on your mail server and publish the public key as a TXT record at <selector>._domainkey.<domain>.

• Enable DNSSEC for your domain — configure it at your DNS registrar and publish DS records.

• Add CAA records to restrict which certificate authorities may issue certificates for your domain. Example: 0 issue "letsencrypt.org"

✓ **Open Redirect**
Pass

✓ No open redirect vulnerabilities detected.

✓ **Subdomain Takeover**
Pass

✓ No dangling CNAMEs or unclaimed service fingerprints found across 2 subdomains.

Conclusion & Recommended Next Steps

1. HTTP Headers	Add missing security headers (CSP, HSTS, X-Frame-Options, etc.).
2. WordPress	Update core, themes and plugins; restrict XML-RPC and REST exposure.
3. ZAP Alerts	Triage each alert and patch confirmed vulnerabilities.
4. Technology Exposure	Patch outdated client libraries, disable directory indexes, and reduce version disclosure.
5. File Exposure	Block sensitive paths in the web server and rotate any exposed credentials.
6. DNS Security	Configure SPF (-all), DMARC (p=quarantine or reject), DKIM signing, and CAA records.

Developer Best Practices

• Standardize security headers and cookie flags in a shared middleware layer so new vibecoded pages inherit safe defaults.

• Keep source, backup, env, and debug artifacts out of the web root, and validate deployment bundles before publish.

• Use authenticated code review and protected branches even for AI-generated code; fast generation increases the need for release guardrails.

• Add pre-production checks for secrets, dependency risk, headers, and exposed debug routes before every deployment.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.